

Matrice des droits et sécurité — GarageFlow

1. Objectif

La matrice des droits permet de définir précisément les accès de chaque type d'utilisateur dans l'application GarageFlow.

Elle permet de sécuriser :

- les données des garages ;
- les comptes utilisateurs ;
- les véhicules des clients ;
- les rendez-vous ;
- les interventions ;
- les notes internes ;
- les notifications.

L'objectif est d'éviter qu'un utilisateur puisse consulter, modifier ou supprimer des données qui ne lui appartiennent pas.

2. Rôles utilisateurs

Visiteur non connecté

Le visiteur non connecté peut uniquement consulter les pages publiques et commencer un parcours de réservation.

Il ne possède pas de compte et n'a pas accès aux données privées.

Client

Le client est un utilisateur inscrit qui peut réserver un rendez-vous, gérer ses véhicules et suivre ses interventions.

Il ne peut accéder qu'à ses propres données.

Employé garage

L'employé est rattaché à un garage.

Il peut gérer les rendez-vous, consulter les fiches véhicules liées au garage, changer les statuts d'intervention et ajouter des notes internes.

Il ne peut pas modifier les paramètres sensibles du garage.

Gérant garage

Le gérant est responsable d'un garage.

Il peut gérer les utilisateurs internes, les horaires, les prestations, les rendez-vous, les interventions et les paramètres du garage.

Il ne peut accéder qu'aux données de son propre garage.

Admin plateforme

L'administrateur plateforme possède une vue globale.

Il peut gérer les garages, les utilisateurs et intervenir sur les données générales de la plateforme.

Il ne doit pas être utilisé pour les actions courantes du garage.

3. Matrice générale des droits

Fonctionnalité	Visiteur	Client	Employé	Gérant	Admin
Consulter une page garage publique	Oui	Oui	Oui	Oui	Oui
Créer un compte client	Oui	Non	Non	Non	Oui
Se connecter	Oui	Oui	Oui	Oui	Oui
Modifier son profil	Non	Oui	Oui	Oui	Oui
Créer un garage	Non	Non	Non	Non	Oui
Modifier un garage	Non	Non	Non	Oui, son garage	Oui
Désactiver un garage	Non	Non	Non	Non	Oui
Gérer les employés	Non	Non	Non	Oui	Oui
Gérer les prestations	Non	Non	Non	Oui	Oui
Gérer les horaires	Non	Non	Non	Oui	Oui
Gérer les indisponibilités	Non	Non	Oui	Oui	Oui
Ajouter un véhicule	Non	Oui	Non	Non	Oui
Voir ses véhicules	Non	Oui	Non	Non	Oui

Fonctionnalité	Visiteur	Client	Employé	Gérant	Admin
Voir les véhicules liés aux RDV du garage	Non	Non	Oui	Oui	Oui
Créer une demande de rendez-vous	Non	Oui	Non	Non	Oui
Voir ses rendez-vous	Non	Oui	Non	Non	Oui
Voir les rendez-vous du garage	Non	Non	Oui	Oui	Oui
Accepter un rendez-vous	Non	Non	Oui	Oui	Oui
Refuser un rendez-vous	Non	Non	Oui	Oui	Oui
Annuler un rendez-vous	Non	Oui, ses RDV	Oui, garage	Oui, garage	Oui
Créer une intervention	Non	Non	Oui	Oui	Oui
Voir une intervention	Non	Oui, ses interventions	Oui, garage	Oui, garage	Oui
Changer un statut d'intervention	Non	Non	Oui	Oui	Oui
Voir les notes internes	Non	Non	Oui	Oui	Oui
Ajouter une note interne	Non	Non	Oui	Oui	Oui
Recevoir une notification	Non	Oui	Oui	Oui	Oui
Voir ses notifications	Non	Oui	Oui	Oui	Oui
Voir les logs d'action	Non	Non	Non	Oui, son garage	Oui

4. Règles d'accès détaillées

4.1 Accès aux garages

Un visiteur peut consulter uniquement les informations publiques d'un garage actif.

Un client peut consulter les garages actifs pour prendre rendez-vous.

Un employé ne peut consulter que les informations du garage auquel il est rattaché.

Un gérant ne peut modifier que son propre garage.

Un administrateur peut consulter, créer, modifier ou désactiver tous les garages.

4.2 Accès aux prestations

Les prestations sont propres à chaque garage.

Un client peut consulter uniquement les prestations actives d'un garage.

Un employé peut consulter les prestations de son garage.

Un gérant peut créer, modifier, activer ou désactiver les prestations de son garage.

Un administrateur peut intervenir sur toutes les prestations.

Règle de sécurité :

Un gérant ne doit jamais pouvoir modifier les prestations d'un autre garage.

4.3 Accès aux horaires et indisponibilités

Les horaires d'ouverture définissent les créneaux disponibles pour la réservation.

Un client peut uniquement consulter les créneaux disponibles.

Un employé peut ajouter une indisponibilité exceptionnelle si le garage doit bloquer un créneau.

Un gérant peut gérer les horaires récurrents et les indisponibilités.

Un administrateur peut intervenir si nécessaire.

Règle de sécurité :

Le système doit toujours vérifier les horaires et indisponibilités côté backend, même si le frontend filtre déjà les créneaux.

4.4 Accès aux véhicules

Un client peut créer et consulter uniquement ses propres véhicules.

Un garage peut consulter les véhicules uniquement s'ils sont liés à un rendez-vous de son garage.

Un employé ou un gérant ne peut pas accéder à tous les véhicules de la plateforme.

Un administrateur peut consulter les véhicules dans un cadre de supervision.

Règle de sécurité :

La vérification ne doit pas seulement porter sur l'identifiant du véhicule, mais aussi sur le lien entre le véhicule, le client et le garage concerné.

4.5 Accès aux rendez-vous

Un client peut créer une demande de rendez-vous pour lui-même et l'un de ses véhicules.

Un client peut consulter ses propres rendez-vous.

Un client peut annuler une demande ou un rendez-vous selon les règles définies par le projet.

Un employé peut consulter, accepter, refuser ou annuler les rendez-vous de son garage.

Un gérant possède les mêmes droits que l'employé, avec en plus les droits de paramétrage.

Un administrateur peut consulter ou modifier les rendez-vous de la plateforme.

Règle de sécurité :

Un garage ne peut pas voir les rendez-vous d'un autre garage.

4.6 Accès aux interventions

Une intervention est créée après confirmation du rendez-vous.

Un client peut voir le suivi de ses propres interventions.

Un client ne peut pas modifier le statut d'une intervention.

Un employé peut modifier le statut d'une intervention liée à son garage.

Un gérant peut modifier les interventions de son garage.

Un administrateur peut consulter ou modifier les interventions si besoin.

Règle de sécurité :

Chaque changement de statut doit être historisé avec l'utilisateur qui a effectué l'action.

4.7 Accès aux notes internes

Les notes internes sont strictement réservées au garage.

Un client ne peut jamais consulter les notes internes.

Un employé peut ajouter une note interne sur une intervention de son garage.

Un gérant peut consulter et ajouter des notes internes sur les interventions de son garage.

Un administrateur peut consulter les notes internes uniquement dans un cadre de supervision.

Règle de sécurité :

Les notes internes ne doivent jamais être renvoyées dans les réponses API destinées au client.

4.8 Accès aux notifications

Une notification est destinée à un utilisateur précis.

Un client peut consulter uniquement ses propres notifications.

Un employé ou un gérant peut recevoir des notifications internes liées à son garage.

Un utilisateur ne peut pas consulter les notifications d'un autre utilisateur.

Règle de sécurité :

Chaque notification doit être filtrée par `id_destinataire`.

4.9 Accès aux logs d'action

Les logs permettent de suivre les actions importantes.

Un client ne peut pas consulter les logs.

Un employé ne peut pas consulter les logs globaux.

Un gérant peut consulter les logs de son garage.

Un administrateur peut consulter les logs de toute la plateforme.

Règle de sécurité :

Les logs doivent aider à comprendre ce qui s'est passé en cas d'erreur, d'action sensible ou de litige.

5. Matrice des accès par données

Donnée	Client	Employé	Gérant	Admin
Son profil	Lecture / modification	Lecture / modification	Lecture / modification	Lecture / modification
Profil d'un autre utilisateur	Non	Non	Employés de son garage	Oui
Garage	Lecture publique	Lecture de son garage	Modification de son garage	Tous droits
Prestations	Lecture	Lecture	Création / modification	Tous droits
Horaires	Lecture indirecte	Lecture	Création / modification	Tous droits
Indisponibilités	Non	Création / lecture	Création / modification	Tous droits
Véhicules	Ses véhicules	Véhicules liés au garage	Véhicules liés au garage	Tous droits
Rendez-vous	Ses rendez- vous	RDV du garage	RDV du garage	Tous droits
Interventions	Ses interventions	Interventions du garage	Interventions du garage	Tous droits
Notes internes	Non	Notes du garage	Notes du garage	Tous droits
Notifications	Ses notifications	Ses notifications	Ses notifications	Tous droits
Logs	Non	Non	Logs du garage	Tous droits

6. Sécurité backend prévue

Authentification

L'application doit vérifier l'identité de l'utilisateur avant de lui donner accès aux fonctionnalités privées.

Les mots de passe doivent être stockés sous forme hashée.

Aucun mot de passe ne doit être stocké en clair.

Autorisation

L'application doit vérifier les droits de l'utilisateur avant chaque action sensible.

Exemples :

- un client ne peut pas modifier un rendez-vous qui ne lui appartient pas ;
 - un employé ne peut pas gérer un garage auquel il n'est pas rattaché ;
 - un gérant ne peut pas modifier les prestations d'un autre garage ;
 - un client ne peut jamais lire les notes internes.
-

Isolation des données par garage

L'isolation des données est une règle centrale du projet.

Chaque requête côté garage doit être filtrée par `id_garage`.

Exemple :

Un employé du Garage A ne doit jamais pouvoir accéder :

- aux rendez-vous du Garage B ;
 - aux prestations du Garage B ;
 - aux interventions du Garage B ;
 - aux notes internes du Garage B.
-

Validation des données

Les données envoyées par l'utilisateur doivent être validées côté frontend et côté backend.

Exemples :

- email valide ;
- mot de passe conforme ;
- date de rendez-vous dans le futur ;
- durée de prestation supérieure à zéro ;
- créneau disponible ;
- véhicule appartenant au client connecté ;
- rendez-vous lié au bon garage.

Le backend reste la source de vérité.

Même si le frontend bloque une erreur, le backend doit refaire les vérifications.

Protection des endpoints

Les endpoints sensibles doivent être protégés.

Exemples :

Endpoint	Protection attendue
Créer une prestation	Gérant ou admin
Modifier les horaires	Gérant ou admin
Voir les RDV garage	Employé, gérant ou admin
Prendre RDV	Client connecté
Changer statut intervention	Employé, gérant ou admin
Voir notes internes	Employé, gérant ou admin
Voir ses notifications	Utilisateur connecté

Traçabilité

Les actions importantes doivent être enregistrées dans `LOG_ACTION`.

Actions à journaliser :

- création d'un rendez-vous ;
- acceptation d'un rendez-vous ;
- refus d'un rendez-vous ;
- annulation d'un rendez-vous ;
- création d'une intervention ;
- changement de statut d'intervention ;
- création ou modification d'une prestation ;
- création ou modification d'une indisponibilité ;
- modification d'un garage.

Cela permet de comprendre qui a fait quoi, quand et sur quelle donnée.

7. Exemples de contrôles métier

Exemple 1 — Un client veut réserver un rendez-vous

Le backend doit vérifier :

- que le client est connecté ;
- que le garage existe et est actif ;
- que la prestation existe et appartient au garage ;

- que le véhicule appartient au client connecté ;
 - que le créneau est dans les horaires d'ouverture ;
 - que le créneau n'est pas indisponible ;
 - qu'il n'existe pas déjà un rendez-vous sur ce créneau.
-

Exemple 2 — Un employé veut changer un statut d'intervention

Le backend doit vérifier :

- que l'utilisateur est connecté ;
 - que l'utilisateur possède le rôle EMPLOYE ou GERANT ;
 - que l'utilisateur est rattaché au garage concerné ;
 - que l'intervention appartient bien à ce garage ;
 - que le nouveau statut existe ;
 - que le changement est enregistré dans l'historique ;
 - qu'une notification est créée si le statut est visible pour le client.
-

Exemple 3 — Un client veut consulter une intervention

Le backend doit vérifier :

- que le client est connecté ;
 - que l'intervention est liée à un rendez-vous du client ;
 - que seules les informations visibles client sont renvoyées ;
 - que les notes internes ne sont jamais incluses dans la réponse.
-

8. Sécurité frontend prévue

Le frontend doit améliorer l'expérience utilisateur, mais ne doit pas être considéré comme une protection suffisante.

Il doit permettre :

- d'afficher ou masquer les menus selon le rôle ;
- d'empêcher l'accès visuel aux pages non autorisées ;
- d'afficher des messages d'erreur clairs ;
- d'afficher des états de chargement ;
- d'afficher des confirmations de succès ou d'échec ;
- de guider l'utilisateur dans son parcours.

Exemples :

- un client ne voit pas le menu "gestion des prestations" ;
- un employé ne voit pas le menu "gestion des garages plateforme" ;
- un gérant ne voit que les données de son garage ;
- un client voit uniquement ses rendez-vous et véhicules.

9. Points à présenter à l'oral

La sécurité du projet repose sur trois niveaux :

1. l'authentification, pour savoir qui est connecté ;
2. l'autorisation, pour savoir ce que l'utilisateur a le droit de faire ;
3. l'isolation des données, pour empêcher un garage ou un client d'accéder aux données d'un autre.

La matrice des droits m'a permis de définir précisément les actions autorisées selon les rôles : administrateur, gérant, employé et client.

J'ai également prévu une journalisation des actions importantes afin de garder une trace des opérations sensibles, comme l'acceptation d'un rendez-vous ou le changement de statut d'une intervention.

Cette approche permet de sécuriser le backend et de rendre l'application plus fiable et maintenable.